HE · HACKING ÉTICO · UT1 / UT5

OSINT
Del dato a la evidencia

Cuaderno de aula · Inicio: jueves 8 de octubre de 2026

Primera sesión de 4 horas · HE-E9 · RA3

> Una investigación reproducible: formular preguntas, consultar fuentes, contrastar identidades y explicar los límites de lo encontrado.

Incluye una ruta sin cuentas ni API, laboratorio sintético, catálogo ampliado de herramientas y plantilla de entrega.

1. Qué haremos mañana

Al terminar podrás entregar un informe breve con seis evidencias trazables, un grafo de relaciones, dos coincidencias descartadas y tres medidas de reducción de exposición. La calidad se mide por la justificación y la reproducibilidad, no por la cantidad de datos personales ni por cuántas herramientas hayas abierto.

Ruta principal: caso sintético incluido en `OSINT-LAB-ALUMNADO.zip`. Funciona sin Internet con Python 3 y Git. Navegador y editor de texto bastan para la mayor parte; ExifTool es una ampliación. **Ruta opcional:** auto-OSINT voluntario sobre identificadores propios, con evidencias redactadas. Ambas rutas permiten la misma valoración; nadie tiene que mostrar información privada ante el grupo.

Esta sesión adelanta el reconocimiento de UT5 y aporta el encuadre inicial de UT1. No sustituye la firma del ROE (HE-E1), la prueba HE-E2 ni las horas oficiales del módulo. La práctica activa HE-E10 queda para otra sesión con infraestructura y alcance preparados.

Minutos	Actividad	Resultado comprobable
0–15	Pregunta de investigación, límites y ejemplo	Objetivo y exclusiones escritos
15–35	Pasivo, directo y local; reconocer errores	Clasificar cinco acciones
35–55	Abrir el kit y crear registro de evidencias	Python/Git comprobados; E01
55–95	Identificadores, fuentes y coincidencias	Tres evidencias y un descarte
95–115	Dominio, certificados y archivo histórico	Separar datos actuales e históricos
115–135	Descanso	Guardar trabajo
135–165	Metadatos e historial Git	Dos evidencias reproducibles
165–190	Grafo, confianza y falsos positivos	Grafo de al menos seis nodos
190–215	Remediación y montaje de HE-E9	Tres medidas verificables
215–235	Revisión por parejas	Reproducir una evidencia ajena
235–240	Entrega y cierre	Informe, CSV y grafo

Reglas operativas

La actividad obligatoria usa exclusivamente archivos sintéticos. En la ampliación en Internet se consultan fuentes públicas dentro de la política del centro y sobre objetivos admitidos; no se investigan compañeros. Un resultado público no autoriza cualquier tratamiento o difusión. Recoge solo lo necesario y evita subir datos reales a servicios externos. Una petición de búsqueda también deja registros en el proveedor.

Si aparece un dato real inesperado, detén ese hilo, no lo difundas y avisa al docente. No verifiques credenciales, no solicites recuperaciones de cuenta y no envíes mensajes. El ROE para cualquier prueba activa debe indicar activos, técnicas, ventana, límites y contacto de parada.

2. Método y registro

Pregunta guía: ¿qué relaciones entre alias, correo, repositorio y dominio están sustentadas por las fuentes del caso, y cuáles son solo hipótesis?

1. **Delimita:** objetivo, finalidad, fuentes permitidas y exclusiones.
2. **Recoge:** conserva el original, registra consulta, herramienta/versión, fecha UTC y estado de la fuente.
3. **Normaliza:** unifica formatos sin borrar la cadena original ni su procedencia.
4. **Contrasta:** busca corroboración independiente. Dos páginas que copian el mismo origen no son dos confirmaciones.
5. **Analiza:** separa observación, inferencia y afirmación no demostrada.
6. **Comunica:** evidencia mínima, confianza, limitaciones y acción correctora comprobable.

Tipo	Ejemplo	Qué puede concluirse
Local	Leer un CSV o Git ya descargado	No necesita una nueva consulta de red
Pasivo respecto del objetivo	Consultar índices de CT, buscadores o archivos	El proveedor conoce la consulta; no significa anonimato
Consulta directa	Abrir un perfil, descargar una web, resolver DNS	Puede producir registros en servicios o resolutores
Enumeración activa	Comprobar cuentas, escanear puertos, sondear rutas	Requiere alcance específico; no es la práctica pasiva obligatoria

Sherlock y Maigret consultan servicios. Holehe utiliza mecanismos de servicios para comprobar cuentas. SpiderFoot y Recon-ng dependen de los módulos seleccionados: no son automáticamente pasivos. Un crawler contacta con la web recorrida. Comprobar que un secreto funciona puede contactar con el proveedor del secreto.

Plantilla de evidencia

```
ID: E01
Pregunta y objetivo autorizado:
Fuente: ruta local o URL exacta
Fecha de consulta UTC: AAAA-MM-DDTHH:MM:SSZ
Fecha del contenido (si existe):
Consulta/comando y versión:
Estado: correcto / parcial / bloqueado / error
Observación literal mínima:
Inferencia y confianza: alta / media / baja
Corroboración y origen independiente:
Limitaciones y posible falso positivo:
Archivo de evidencia + SHA-256:
Medida de reducción de exposición y comprobación:
```

Cero resultados: escribe «esta consulta no devolvió resultados en esta fuente y momento». Un CAPTCHA, HTTP 429, API sin clave, error DNS o módulo roto es *consulta no concluyente*, no ausencia comprobada. Ni siquiera una consulta correcta demuestra que el dato no existe en otras fuentes.

3. Laboratorio reproducible sin Internet

Preparación · 35–55 min

Descomprime el ZIP en una carpeta de trabajo. Abre `LEEME.html`. El conjunto es ficticio: no envíes alias o dominios del caso a buscadores públicos. Los nombres bajo `.example` se usan como identificadores documentales, no como servicios reales.

```
python3 --version
git --version
python3 verificar_kit.py
python3 preparar_repo.py
```

En Windows puede usarse `py -3` en lugar de `python3`. Git debe estar instalado para crear el repositorio; si no lo está, usa `datos/historial-git.txt`, indica «análisis de captura» y conserva la misma trazabilidad.

Práctica A · Identidad y coincidencias

Lee `datos/perfiles.csv`, `datos/boletin.txt` y `datos/repositorio.txt`. Anota alias, identificadores y fecha. Formula dos relaciones demostrables y dos coincidencias que debas descartar o mantener sin atribuir. No atribuyas una cuenta solo porque repita un alias.

```
python3 explorar.py buscar kestrel_ova
python3 explorar.py buscar mail.xest.example
```

Checkpoint: otra persona puede encontrar la fila exacta y explicar por qué apoya tu afirmación. Debes distinguir una cuenta actual de una captura antigua y un homónimo de una identidad vinculada.

Práctica B · Dominio e histórico

Analiza `datos/certificados.json` y `datos/archivo.csv`. Extrae nombres únicos, diferencia comodines de hosts concretos y distingue «aparece en un certificado» de «existe, responde y pertenece hoy al objetivo». El fichero es una simulación de resultados CT, no una consulta realizada a crt.sh.

```
python3 explorar.py certificados
```

Relaciona una URL histórica con su fecha de captura. No supongas que el servicio sigue abierto ni que el contenido histórico es vigente. En una investigación real, CT, Wayback y DNS pasivo pueden tener lagunas y distintas fechas de observación.

Práctica C · Metadatos

Abre `datos/cartel.svg` como texto y como imagen. Localiza autor, fecha y coordenadas en los metadatos; compáralos con la parte visible. Son valores sintéticos que demuestran exposición, no una prueba de residencia ni de rutina.

```
python3 explorar.py metadatos
```

Guarda una copia saneada eliminando el bloque `<metadata>…</metadata>`, sin tocar el original. Comprueba que la copia se abre y que esos campos desaparecen. Para fotos propias, ampliación con ExifTool:

```
exiftool -a -G1 -s foto-propia.jpg
# Trabaja únicamente sobre una copia de prueba:
exiftool -all= copia-foto.jpg
exiftool -a -G1 -s copia-foto.jpg
```

ExifTool puede conservar una copia de respaldo con los datos anteriores; no la publiques. Quitar metadatos no elimina texto visible, rostros, nombres de archivo ni publicaciones ya realizadas.

Práctica D · Lo borrado en Git

El script prepara dos commits con identidad ficticia en `repo-demo`. El último ya no contiene el marcador de prueba. No hay una clave válida ni un servicio al que conectarse.

```
git -C repo-demo log --all --format='%h %aI %ae %s'
git -C repo-demo log --all -p -- configuracion.txt
git -C repo-demo show HEAD~1:configuracion.txt
```

Localiza el marcador en el commit anterior y documenta archivo y commit. Borrar una línea del último estado no borra el historial. En un caso real, la primera medida sobre un secreto expuesto es revocarlo o rotarlo; reescribir historial no deshace copias ajenas.

TruffleHog, ampliación: el detector puede no reconocer un marcador inventado. No se promete un resultado «verified». Usa análisis sin verificación externa cuando proceda y comprueba la sintaxis de tu versión con `trufflehog git --help`. Para este ejercicio la prueba determinista es el historial Git, no el escáner.

4. Grafo, informe y remediación

Crea al menos seis nodos: alias, perfil, correo, repositorio, dominio y documento. Cada arista debe tener etiqueta, evidencia y confianza. Puedes usar la hoja CSV incluida, papel, diagrams.net o un grafo local; no necesitas una cuenta de Maltego.

Origen → destino	Relación	Justificación exigida
Perfil → correo	«publica»	Fuente concreta y fecha
Repositorio → correo	«autor declarado»	Commit; no prueba titularidad verificada
Certificado → dominio	«incluye nombre»	Entrada y validez temporal
Alias antiguo → perfil actual	«posible relación»	No convertir semejanza en identidad cierta

Entrega HE-E9

1. Resumen: pregunta, objetivo, alcance y respuesta en cinco líneas.
2. Método: fuentes, consultas y fechas; separar datos locales de consultas reales.
3. Seis evidencias con observación y confianza; se admiten resultados negativos bien descritos, sin inventar datos.
4. Grafo y dos falsos positivos descartados o no atribuidos.
5. Tres medidas: qué se haría, por qué y cómo verificar el resultado. En el caso sintético ejecuta el saneado de la copia y documenta las otras como simulación.
6. Limitaciones y archivos: CSV, evidencia mínima y hashes. Nunca adjuntes una contraseña real.

La propuesta de valoración para esta sesión es: alcance y método 20 %, trazabilidad 30 %, contraste y grafo 25 %, remediación 15 %, claridad 10 %. **Es una propuesta didáctica, no modifica la rúbrica oficial R2 ni los pesos por RA del centro.**

Autoevaluación final

¿He confundido nombre repetido con identidad? ¿He atribuido una fecha de archivo a la fecha del hecho? ¿He tratado un fallo de API como cero resultados? ¿Puede un compañero repetir una consulta con la información entregada? ¿He indicado qué es sintético? ¿He distinguido medida ejecutada de medida propuesta?

5. Ampliación en Internet

Este bloque es opcional. Se usa con identificadores propios o un dominio público expresamente autorizado. La ruta sintética no necesita estas consultas. Nunca sustituyas un dominio interno por una organización cualquiera para obtener resultados.

Buscadores y archivos

Ensaya comillas para frases, `site:` para dominio y `filetype:` para documentos. El soporte de operadores varía según el buscador. No se usa `cache:` como requisito. Conserva consulta y fecha, identifica el origen y abre solo resultados dentro del alcance. La ausencia en un buscador no demuestra eliminación.

```
"TU_ALIAS_PROPIO" site:github.com
site:DOMINIO_PUBLICO_AUTORIZADO filetype:pdf
```

Son plantillas; reemplaza el marcador antes de usarlas. Los dominios `xest.local` del curso no deben buscarse en CT o Wayback esperando que aparezcan los hosts del laboratorio. Para esos hosts se usa el inventario entregado por el profesor.

Certificados y subdominios

Consulta crt.sh manualmente y conserva la respuesta. Con subfinder, consulta primero `subfinder -h` y configura solo proveedores aprobados. Las claves y cuotas varían; un nombre encontrado no demuestra servicio activo. Resolverlo o sondearlo es otra operación y debe registrarse como tal.

Alias

```
pipx install sherlock-project
sherlock --help
# Después de elegir únicamente tu alias y sitios permitidos:
sherlock TU_ALIAS_PROPIO --site GitHub --timeout 15
```

Si el sitio no está disponible en la versión instalada, elige una fuente compatible indicada por la ayuda. Comprueba manualmente cualquier coincidencia. Maigret amplía análisis e informes, pero no mejora por sí solo la certeza de una atribución. No ejecutes barridos masivos como primer ejercicio.

Brechas y contraseñas

Have I Been Pwned separa búsqueda de cuentas y Pwned Passwords. La consulta por rango de hash corresponde a contraseñas, no a correos. Nunca introduzcas una contraseña personal en una demostración ni uses una supuesta filtración para iniciar sesión. Para el aula se incluye una tabla ficticia de incidentes:

aparecer en dos filas no prueba reutilización de contraseñas.

Frameworks y redes sociales

SpiderFoot, Recon-ng y Maltego son ampliaciones tras comprender el método. Selecciona módulos y destinos explícitos. Comprueba condiciones, autenticación y límites de cada servicio. No se garantiza que un scraper funcione hoy en una plataforma por el simple hecho de que su repositorio exista. Ante bloqueo usa capturas sintéticas y registra la limitación.

6. Preparación del puesto

Base mañana: navegador, editor, Python 3, Git y kit local. En Kali/Debian, preparación previa por el docente:

```
sudo apt update
sudo apt install -y python3 git curl jq pipx libimage-exiftool-perl
python3 --version
git --version
exiftool -ver
```

Estos comandos son para una VM Kali/Debian, no para la terminal de macOS o Windows. En Windows utiliza Python 3 y Git para Windows; en macOS comprueba primero los que ya tienes. No instales toda la distribución de herramientas para completar la primera sesión.

Congela las versiones probadas antes de clase, conserva instaladores o una VM y anota la versión en las evidencias. No uses actualizaciones globales a última hora. Revisa la documentación oficial para herramientas opcionales: no se presupone que `pipx install nombre` funcione para cualquier repositorio.

Problema	Plan B
Sin Internet o API	Kit sintético completo, misma entrega
Sin Git	Captura de historial incluida, señalar análisis de captura
Sin ExifTool	Metadatos SVG con Python/editor
CAPTCHA, 403 o 429	Registrar bloqueo, no insistir ni clasificarlo como ausencia
No aparecen cuentas	Contrastar fuente y consulta; usar caso local para practicar atribución
No hay SOC	La clase OSINT sigue; diferir medición activa HE-E10

7. Catálogo ampliado: 66 recursos

Catálogo de selección, no instalación masiva. Las rutas esenciales se revisaron con documentación oficial; los recursos de ampliación conservan su enlace para comprobar requisitos antes de usarlos. No se han ejecutado todas las herramientas ni se certifica la disponibilidad de cada servicio. Costes, API y compatibilidad cambian.

Prioridad mañana: navegador, Python, Git, CSV, metadatos y grafo. Después: buscadores, crt.sh, archivo histórico y Sherlock. Para otra sesión: automatizadores y APIs. Twint y herramientas históricas no se proponen como dependencias.

Búsqueda y archivo

Herramienta / enlace oficial	Utilidad	Requisito o límite
Google / Bing / DuckDuckGo	Consultas manuales y operadores	Web; registra diferencias de cobertura
Wayback Machine	Versiones históricas	Puede faltar contenido; fecha de captura no es fecha del hecho
Common Crawl	Índices y corpus web	Ampliación técnica; datos históricos
OSINT Framework	Directorio por categorías	Índice, no garantía de calidad de cada recurso
Bellingcat Toolkit	Selección de recursos y métodos	Consultar requisitos de cada recurso
GHDB / Pagodo	Consultas especializadas	Opcional; automatización sujeta a límites

Identificadores

Herramienta / enlace oficial	Utilidad	Requisito o límite
Sherlock	Comprobar alias en servicios	Consulta directa; validar coincidencias
Maigret	Alias e informes de perfiles	Consulta directa; no atribuye identidades por sí solo
WhatsMyName	Patrones de detección de usuarios	Una coincidencia es una pista
Blackbird	Búsqueda de identificadores	Opcional; verificar compatibilidad

Correo y teléfono

Herramienta / enlace oficial	Utilidad	Requisito o límite
Have I Been Pwned	Exposición de cuentas; Pwned Passwords	Solo identificadores propios/autorizados; API según modalidad
Holehe	Comprobación de registro de correo	Interacciona con servicios; fuera de la ruta pasiva obligatoria
h8mail	Correlación de correo con fuentes	Proveedores y claves variables; no adquirir volcados reales para el aula
GHunt	Información asociada a servicios Google	Autenticación y resultados dependen del proveedor
Mosint	Agregación de fuentes de correo	Ampliación; revisar configuración y cuotas
PhoneInfoga	Información y referencias de números	No revela ubicación en tiempo real ni garantiza titularidad
Ignorant	Comprobación de números en servicios	Interacción activa con servicios; no necesaria mañana

Dominios e infraestructura

Herramienta / enlace oficial	Utilidad	Requisito o límite
crt.sh	Transparencia de certificados	Web; ni vigencia del servicio ni inventario completo
ICANN Lookup	Consulta de datos de registro	Puede haber datos redactados
subfinder	Fuentes pasivas de subdominios	Algunas fuentes requieren API; separar de resolución activa
Amass	Mapeo de superficie externa	Modos y sintaxis según versión; definir alcance
theHarvester	Agregación por dominio	Seguir instalación oficial actual; fuentes y requisitos cambian
DNSdumpster	Referencias e inventario DNS	Cobertura y cuotas variables
SecurityTrails	Datos DNS e históricos	Cuenta/plan; no asumir acceso gratuito completo

Herramienta / enlace oficial	Utilidad	Requisito o límite
waybackurls	URLs archivadas	No abrir URLs descubiertas automáticamente
gau	URLs de varias fuentes	Histórico no equivale a endpoint actual
dnstwist	Variantes de dominio	Resolver o consultar variantes genera tráfico

Índices de exposición

Herramienta / enlace oficial	Utilidad	Requisito o límite
Shodan	Servicios observados por el proveedor	Consultar resultados existentes; no pedir escaneo
Censys	Hosts, certificados y exposición	Cuenta/plan; cobertura y fechas variables
ZoomEye	Búsqueda de exposición	Cuenta/plan; no demuestra vulnerabilidad
FOFA	Buscador de activos	Cuenta y límites del proveedor
Netlas	Datos de servicios y dominios	Cuenta/plan; registrar fecha de observación

Imágenes y documentos

Herramienta / enlace oficial	Utilidad	Requisito o límite
ExifTool	Lectura y edición local de metadatos	Conservar original; revisar copia saneada
Google Lens	Búsqueda visual	La imagen enviada sale del equipo
Bing Visual Search	Búsqueda visual	Verificar resultados manualmente
Yandex Images	Búsqueda inversa	No asumir superioridad ni identidad facial
TinEye	Coincidencias y reutilización de imágenes	No hallar coincidencias no prueba originalidad

Herramienta / enlace oficial	Utilidad	Requisito o límite
InVID-WeVerify	Verificación audiovisual	Compatibilidad del navegador; comprobación previa
Metagoofil	Localizar documentos	Las descargas contactan con sus servidores

Geolocalización

Herramienta / enlace oficial	Utilidad	Requisito o límite
Google Earth / Street View	Contraste de elementos del terreno	Fechas de imágenes y cobertura variables
OpenStreetMap	Cartografía y referencias	Contrastar exactitud y actualidad
SunCalc	Posición solar para una hipótesis	Necesita lugar/fecha; sombras solas no prueban ubicación
GeoSpy	Estimaciones visuales con IA	Ampliación; verificar acceso y tratar resultado como hipótesis

Repositorios y secretos

Herramienta / enlace oficial	Utilidad	Requisito o límite
Git	Historial, autores declarados y cambios	Local; autor de commit puede ser suplantado
GitHub Code Search	Búsqueda en código accesible	No verificar ni reutilizar secretos encontrados
Gitleaks	Detección local de patrones de secretos	Un patrón no prueba validez; posible falso negativo
TruffleHog	Detección y, opcionalmente, verificación	Desactivar verificación externa en la práctica local

Grafos y automatización

Herramienta / enlace oficial	Utilidad	Requisito o límite
SpiderFoot	Correlación modular	Auditar módulos; puede ejecutar acciones activas
Recon-ng	Workspaces y módulos	Módulos y API se preparan antes de clase
Maltego	Relaciones y transforms	Cuenta/licencia y cuotas; transforms pueden enviar datos
sn0int	Investigación modular	Revisar cada módulo y sus conexiones
Gephi	Grafos locales desde CSV	No obtiene evidencia: representa relaciones
diagrams.net	Dibujo manual de grafos	Usar versión local para datos sensibles

Web y redes sociales

Herramienta / enlace oficial	Utilidad	Requisito o límite
Instaloader	Contenido y metadatos de Instagram	Autenticación, restricciones y cambios de plataforma
snscrape	Scrapers de varias plataformas	No usar como requisito; probar plataforma concreta
Toutatis / Osintgram	Recursos especializados de Instagram	Solo referencia opcional; no garantizar funcionamiento
Photon	Crawler de enlaces y contenido	Activo respecto de la web recorrida
FinalRecon	Reconocimiento web combinado	Revisar acciones; no asumir modo pasivo

Empresas y registros

Herramienta / enlace oficial	Utilidad	Requisito o límite
BORME	Publicaciones mercantiles españolas	Fuente primaria; comprobar fecha y sociedad

Herramienta / enlace oficial	Utilidad	Requisito o límite
OpenCorporates	Referencias de sociedades	Contrastar con registro original y jurisdicción
Aleph / OCCRP	Colecciones documentales	Acceso/cobertura variables; datos requieren contexto

Fuentes restringidas y dark web

Herramienta / enlace oficial	Utilidad	Requisito o límite
Intelligence X	Búsqueda en distintas colecciones	Cuenta/plan; no descargar datos personales para la práctica
DeHashed	Fuentes de exposición de datos	Acceso sujeto al proveedor; usar simulación en aula
Ahmia	Índice de servicios onion	Solo explicación metodológica mañana
Tor Browser	Navegación por la red Tor	No convierte una actividad en autorizada
TorBot / OnionScan	Recursos de exploración onion	Referencia avanzada; revisar mantenimiento, no desplegar mañana

8. Referencias y alcance de la revisión

Preparado el 7 de octubre de 2026 a partir del manual HTML, la guía HE y las fichas UT5/arsenal de la carpeta aportada. Se mantienen las ocho UT y los entregables HE-E1 a HE-E16. Esta edición incorpora una práctica sintética nueva; sus datos no describen personas reales.

- Material fuente de HE
- Instalación de Sherlock
- SpiderFoot y selección de módulos
- Recon-ng
- theHarvester: requisitos y fuentes
- Subfinder: reconocimiento pasivo
- TruffleHog: resultados y verificación
- HIBP: cuentas y Pwned Passwords
- Código Penal: texto consolidado, arts. 197 y siguientes
- RGPD: principios y licitud, arts. 5 y 6
- DVWA: código SQLi nivel high

Precisiones legales: que un dato sea público no elimina las obligaciones sobre su tratamiento. El consentimiento no es la única base jurídica posible y un ROE no autoriza cualquier conducta. Los arts. 197 bis y 197 ter no son equivalentes: este último trata determinados instrumentos o credenciales con finalidad delictiva; no convierte toda herramienta de doble uso en ilícita. La política docente puede ser más restrictiva que el umbral penal. Estas precisiones sustituyen formulaciones categóricas del material anterior.

Validación: se comprueban el kit local y la generación de documentos. Las prácticas de red, los contenedores, la radio y las integraciones con SOC/PPS requieren ensayo en el entorno del centro. No se han ejecutado contra infraestructura real desde esta preparación.